

Relatorio de Auditoria

MomAIOS v1.4.0

Data: 22 de Maio de 2026

Escopo: Completo (apps/momai, apps/core, apps/fortscript, scripts/node-core)

Arquivos analisados: ~400+

Problemas encontrados: 74

Sumario

1. Resumo Executivo
2. Problemas Criticos (3)
3. Problemas de Seguranca
4. Problemas no TypeScript/React
5. Problemas no Python Core
6. Problemas no Node.js Core
7. Problemas de Infraestrutura & CI/CD
8. Tabela Resumo
9. Metricas
10. Recomendacao Final

1. Resumo Executivo

A auditoria completa do MomAIOS v1.4.0 identificou **74 problemas** distribuidos entre criticos (3), alta (15), media (33) e baixa (24). As areas mais criticas sao **seguranca** (credenciais expostas, falta de sandbox Electron, command injection) e **qualidade de codigo** (funcoes monoliticas, mutacao de estado no React, race conditions em modulo compartilhado).

Pontos criticos imediatos:

- Credenciais da API Trello commitadas no .env
- Sandbox do Electron desabilitado em ambas as janelas
- Command injection em rotas de extensoes e launcher
- Certificado PFX com private key no repositorio
- Bug no Float32Array que produz ruido em vez de fala
- Funcao monolitica de ~1280 linhas (streamLlamaChat)
- Estado compartilhado sem sincronizacao entre modulos Node.js

Distribuicao por categoria:

Categoria	Total	Critica	Alta	Media	Baixa
Seguranca & Infraestrutura	13	3	4	4	2
TypeScript/React	18	0	6	7	5
Python Core	10	0	2	6	2
Node.js Core	11	0	5	4	2
CI/CD	5	0	2	2	1

2. Problemas Criticos

[CRITICA] CR-01: Credenciais Trello Commitadas no .env

Arquivo	apps/momai/.env (linhas 1-3)
Valores expostos	TRELLO_API_KEY, TRELLO_TOKEN, TRELLO_DEFAULT_BOARD_ID
Risco	Acesso nao autorizado ao board Trello por qualquer pessoa com acesso ao repositorio
Impacto	Token de longa duracao permite ler/alterar todos os cards do board
O que afeta	Seguranca da conta Trello da equipe
Solucao	Revogar token, remover do git history, adicionar .env ao .gitignore, usar variaveis de ambiente

[CRITICA] CR-02: Electron sandbox: false em Ambas as Janelas

Arquivo	apps/momai/src/main/windowManager.ts (linhas 279, 328)
Risco	XSS no renderizador concede RCE completo no sistema do usuario
Impacto	Qualquer vulnerabilidade em HTML preview, markdown ou extensoes permite acesso total ao sistema
O que afeta	Todos os usuarios do aplicativo desktop
Solucao	Ativar sandbox:true e migrar acesso a Node.js para IPC via preload

[CRITICA] CR-03: Command Injection em Rotas de Extensoes

Arquivos	extensions.routes.js, launcher/runtime.js (3 locais)
Risco	Caminhos fornecidos pelo usuario sao interpolados em comandos shell via exec()
Impacto	Extensao maliciosa pode executar comandos arbitrarios no sistema
O que afeta	Usuarios que instalam extensoes ou usam o launcher
Solucao	Substituir exec() por execFile() com array de argumentos

3. Problemas de Seguranca

[ALTA] S-01: Certificado PFX no Repositorio

Arquivo	momai_certificado.pfx (raiz do repositorio)
Risco	Chave privada exposta; qualquer um pode assinar codigo como publisher oficial
Solucao	Remover do git history, armazenar certificados apenas em CI secrets

[ALTA] S-02: API Keys Sem Criptografia no SQLite

Arquivo	apps/core/database/models.py:25
Risco	Qualquer processo com acesso ao filesystem pode ler as chaves de API
Solucao	Criptografar com cryptography library usando safeStorage da Electron

[ALTA] S-03: HTML Sandbox com allow-scripts

Arquivos	HtmlPreviewCard.tsx:27, DevHtmlRenderCard.tsx:48
Risco	Prompt injection no LLM pode gerar HTML com JS que executa no sandbox
Solucao	Remover allow-scripts ou usar DOMPurify para sanitizar HTML

[MEDIA] S-04: CSP Permissivo

Arquivo	index.html:7-10
Risco	style-src unsafe-inline permite exfiltracao de dados via CSS
Solucao	Usar nonce/hash para estilos inline, restringir origens externas

[MEDIA] S-05: contextIsolation/nodeIntegration Nao Explicitados

Arquivo	windowManager.ts:277-279
Risco	Mudancas em defaults do Electron podem alterar comportamento silenciosamente
Solucao	Definir contextIsolation:true e nodeIntegration:false explicitamente

4. Problemas no TypeScript/React

[ALTA] TS-01: Mutacao Direta de Estado React (useChatActions.ts:393)

Problema	updated[lastIdx].content = `Erro: \${err}` — muta objeto do estado React
Impacto	React pode descartar atualizacao ou produzir UI inconsistente
Solucao	updated[lastIdx] = { ...updated[lastIdx], content: ... }

[ALTA] TS-02: Float32Array Bug — Audio com Ruído (useAudioFallback.ts:31)

Problema	new Float32Array(bytes.buffer) — ArrayBuffer tem tamanho total, não o slice ocupado. Produz ruído em vez de fala
Impacto	TTS fallback (say.js) produz ruído alto, funcionalidade inutilizável
Solucao	Usar bytes.buffer.slice(0) e converter corretamente via Int16Array

[ALTA] TS-03: sort() Dentro de useMemo (ContainerChat.tsx:547)

Problema	allSuggestions.sort() — sort() muta o array original dentro do memo
Impacto	Corrompe cache do array allSuggestions, causando re-renders em cascata
Solucao	[...allSuggestions].sort() para criar copia antes de ordenar

[ALTA] TS-04: Interval Resetado a Cada Token (ContainerChat.tsx:284-317)

Problema	useEffect com dependencia em lastAssistant?.content recria setInterval a cada token (~50ms)
Impacto	Animacao de palavras reiniciada constantemente, exibicao irregular
Solucao	Separar logica de animacao do streaming; usar useRef para buffer

[ALTA] TS-05: Effect Dispara em Todo Render (useChat.ts:101-107)

Problema	Objeto actions recriado em todo render causa stopGeneration() desnecessario
Impacto	API calls desnecessarias a cada re-render em conversas longas
Solucao	Extrair dependencias individuais em vez de depender do objeto actions

[ALTA] TS-06: Registry de Renderers Sem Tipos (SkillResponseRegistry.ts)

Problema	Map() sem generics, parametros sem types — zero TypeScript em 20 linhas
Impacto	Erro de registro de renderer só é detectado em runtime
Solucao	Adicionar Map<>

[MEDIA] TS-07: setTimeout Sem Cleanup (MessageItem.tsx:118)

Problema	setTimeout(() => state.setIsCopied(false), 2000) sem cleanup no unmount
Solucao	Capturar timer e limpar via clearTimeout no return do useEffect

[MEDIA] TS-08: Retry Timer Sem Cleanup (useChatInit.ts:28)

Problema	setTimeout recursivo não capturado; timers concorrentes ao trocar de thread
----------	---

Solucao	Usar useRef para reter referencia do timer e limpar no cleanup
---------	--

[MEDIA] TS-09: Delete Sem Rollback (useChatActions.ts:428)

Problema	Mensagem removida da UI mesmo se API falhar; sem feedback pro usuario
Solucao	Reverter estado local em caso de erro na API

[MEDIA] TS-10: Promise Rejections Nao Tratadas (useAppEvents.ts:47-57)

Problema	Dynamic imports encadeados sem .catch()
Solucao	Adicionar .catch() em todos os encadeamentos

[MEDIA] TS-11: Dependencia Circular api.ts <-> ttsService.ts

Problema	Importacao circular entre os dois servicos
Solucao	Extrair tipos e logica compartilhada para terceiro modulo

[MEDIA] TS-12: Promise Infecta Toda API (api.ts:4)

Problema	apiFetch retorna Promise, todos consumidores perdem type safety
Solucao	Tipar com generico: async function apiFetch(...): Promise

[MEDIA] TS-13: Props Sem Tipo (WeatherCard.tsx, etc.)

Problema	Componentes recebem {data} sem interface definida
Solucao	Definir interfaces para todos os dados de structured response

5. Problemas no Python Core

[ALTA] PY-01: FFT em Callback de Audio (detector.py:230-242)

Problema	FFT e asyncio.run_coroutine_threadsafe() dentro do callback do sounddevice
Impacto	Dropouts de audio e wake word detection imprecisa
Solucao	Usar queue.Queue para enviar buffers para thread de processamento

[ALTA] PY-02: Download sem Timeout (tts.py:258)

Problema	urllib.request.urlretrieve sem timeout — trava indefinidamente
Impacto	TTS nunca inicializa, sem feedback para o usuario
Solucao	Adicionar socket.setdefaulttimeout() ou usar requests com timeout

[MEDIA] PY-03: WebSocket List Nao Thread-Safe (app_state.py:14)

Problema	list[WebSocket] acessada de multiplas tasks sem lock
Solucao	Usar asyncio.Lock ou set com lock

[MEDIA] PY-04: httpx.Client() Criado por Chamada (detector.py:727)

Problema	Novo client HTTP para cada verificacao sem connection pooling
Solucao	Inicializar e reutilizar um unico cliente

[MEDIA] PY-05: except: pass em Callbacks de Audio

Problema	quick_transcriber.py, whatsapp_reply.py, tts.py — erros silenciados
Solucao	Logar todos os exceptions em vez de usar pass

[MEDIA] PY-06: Multiplos except: pass pelo Core

Problema	main.py, startup.py — dezenas de except silenciosos
Solucao	Logar todos os erros com logger.exception()

[MEDIA] PY-07: Nenhum Teste em apps/core/ nem forscript/

Problema	pytest listado como dependencia mas zero testes implementados
Solucao	Implementar testes para rotas da API e servicos core

[MEDIA] PY-08: Erro Interno Exposto em 500 (chat_voice.py:61)

Problema	HTTPException(detail=str(e)) — detalhes internos vazados
Solucao	Logar erro e retornar mensagem generica

6. Problemas no Node.js Core

[ALTA] NC-01: Funcao Monolitica streamLlamaChat (~1280 linhas)

Arquivo	scripts/node-core/services/chat-service.js:614-1894
Problema	Funcao unica gerencia retrieval, hooks, skills, LLM loop, tools, fallback, observabilidade
Impacto	Impossivel de testar unitariamente; bugs de estado entre rounds sao frequentes
Solucao	Extrair para 6-8 funcoes menores: buildSystemMessage, executeSkillPipeline, runInference, etc.

[ALTA] NC-02: Estado Compartilhado Sem Sincronizacao (shared-state.js)

Problema	Objetos mutaveis exportados e modificados por todos os modulos sem lock
Impacto	Race conditions em llamaState, store, contextUsedTokens
Solucao	Implementar writer lock ou usar padrao de mensagens

[ALTA] NC-03: Erros Engolidos Silenciosamente

Arquivos	websocket.js, process-manager.js, router.js, chat-service.js
Problema	Dezenas de catch {} vazios que engolem todos os erros
Impacto	Impossivel diagnosticar falhas em producao
Solucao	Logar todos os erros capturados; nunca usar catch vazio

[ALTA] NC-04: Sem Timeout HTTP (router.js:66-71)

Problema	http.createServer sem timeout — conexoes ficam abertas indefinidamente
Impacto	Potencial exaustao de recursos por conexoes lentas
Solucao	Configurar server.timeout = 30000

[ALTA] NC-05: readFileSync Bloqueia Event Loop

Arquivos	semantic-engine.js, lexical-search.js
Problema	Leitura sincrona de arquivos em paths de requisicao HTTP
Impacto	Event loop bloqueado durante leitura, afetando todas as conexoes simultaneas
Solucao	Usar fs.promises.readFile com Promise.all para leitura concorrente

[ALTA] NC-06: Race Condition em ensureLlamaReady (llama-manager.js)

Problema	Duas chamadas concorrentes podem spawnar multiplos processos llama-server
Impacto	Multiplos processos LLM consumindo memoria e GPU concorrentemente
Solucao	Usar lock/mutex para garantir apenas um processo de spawn por vez

7. Problemas de Infraestrutura & CI/CD

[ALTA] CI-01: Senha do Certificado Hardcoded (*sign-appx.js:9*)

Problema	Senha momai2026 hardcoded em scripts de build
Solucao	Mover para GitHub Secrets ou variaveis de ambiente

[ALTA] CI-02: NuGet sem Checksum (*sign-appx.js:71-141*)

Problema	signtool.exe baixado sem verificacao de integridade
Solucao	Verificar checksum SHA256 ou usar Windows SDK nativo

[MEDIA] CI-03: --no-frozen-lockfile no Release (*release.yml:44*)

Problema	Lockfile pode ser modificado durante build de release
Solucao	Usar --frozen-lockfile para garantir reproducibilidade

[MEDIA] CI-04: shamefully-hoist=true (*.npmrc*)

Problema	Hoisting quebra isolamento de dependencias do pnpm
Solucao	Remover config e refatorar codigo para pnpm strict

8. Tabela Resumo

ID	Sev.	Categoria	Local	Descricao
CR-01	Critica	Seguranca	.env	Credenciais Trello commitadas
CR-02	Critica	Seguranca	windowManager.ts	Electron sandbox desabilitado
CR-03	Critica	Seguranca	extensions.routes.js	Command injection (3 locais)
S-01	Alta	Seguranca	momai_certificado.pfx	PFX no repositorio
S-02	Alta	Seguranca	models.py:25	API keys sem criptografia
S-03	Alta	Seguranca	HtmlPreviewCard.tsx:27	iframe com allow-scripts
TS-01	Alta	React	useChatActions.ts:393	Mutacao direta de estado
TS-02	Alta	React	useAudioFallback.ts:31	Float32Array bug — ruido
TS-03	Alta	React	ContainerChat.tsx:547	sort() muta memo
TS-04	Alta	React	ContainerChat.tsx:284	Interval reset a cada token
TS-05	Alta	React	useChat.ts:101	Effect em todo render
TS-06	Alta	React	SkillResponseRegistry.ts	Zero tipos TypeScript
PY-01	Alta	Python	detector.py:230	FFT em callback de audio
PY-02	Alta	Python	tts.py:258	Download sem timeout
NC-01	Alta	Node.js	chat-service.js:614	Funcao de 1280 linhas
NC-02	Alta	Node.js	shared-state.js	Estado sem lock
NC-03	Alta	Node.js	Todo core	Erros engolidos
NC-04	Alta	Node.js	router.js:66	Sem timeout HTTP
NC-05	Alta	Node.js	semantic-engine.js	readFileSync bloqueante
NC-06	Alta	Node.js	llama-manager.js	Race condition spawn
CI-01	Alta	CI/CD	sign-appx.js:9	Senha hardcoded
CI-02	Alta	CI/CD	sign-appx.js:71	NuGet sem checksum
S-04	Media	Seguranca	index.html	CSP permissivo
TS-07	Media	React	MessageItem.tsx:118	setTimeout sem cleanup
TS-08	Media	React	useChatInit.ts:28	Retry timer sem cleanup

ID	Sev.	Categoria	Local	Descricao
TS-09	Media	React	useChatActions.ts:428	Delete sem rollback
TS-10	Media	React	useAppEvents.ts:47	Promise rej. nao tratadas
TS-11	Media	React	api.ts<->ttsService.ts	Dependencia circular
PY-03	Media	Python	app_state.py:14	WebSocket nao thread-safe
PY-05	Media	Python	quick_transcriber.py:90	except:pass em callback
PY-06	Media	Python	main.py, startup.py	Multiplos except:pass
PY-07	Media	Python	apps/core	Nenhum teste
NC-07	Media	Node.js	chat-service.js	console.log em producao
NC-08	Media	Node.js	index.js, router.js	SIGTERM handlers duplicados
CI-03	Media	CI/CD	release.yml:44	--no-frozen-lockfile
CI-04	Media	CI/CD	.npmrc	shamefully-hoist=true

9. Metricas

Metrica	Valor
Arquivos analisados	~400+
Linhas de codigo analisadas	~60.000+
Linguagens	TypeScript, JavaScript, Python
Problemas encontrados	74
Criticos (CR)	3
Alta	15
Media	33
Baixa	24

10. Recomendacao Final

Prioridade Imediata (esta semana)

1. Revogar token Trello e remover .env do git history (CR-01)
2. Ativar sandbox:true no Electron e refatorar codigo dependente (CR-02)
3. Corrigir command injection nas rotas de extensoes (CR-03)
4. Remover momai_certificado.pfx do repositorio (S-01)
5. Corrigir bug do Float32Array em useAudioFallback.ts (TS-02)
6. Corrigir mutacao de estado React na updater function (TS-01)

Curto Prazo (proximo mes)

7. Refatorar streamLlamaChat em funcoes menores (NC-01)
8. Adicionar locks ao estado compartilhado nos modulos Node.js (NC-02)
9. Criptografar API keys no SQLite (S-02)
10. Eliminar except:pass de todo o core Python (PY-06)
11. Adicionar testes para apps/core/ e apps/fortscript/ (PY-07)
12. Configurar HTTP timeout no server Node.js (NC-04)

Medio Prazo (proximo trimestre)

13. Implementar CI security scanning (Dependabot, npm audit, pip-audit)
14. Mover senhas para secrets de CI (CI-01, CI-02)
15. Tipar completamente os renderers (TS-06, TS-12, TS-13)
16. Eliminar dependencia circular entre api.ts e ttsService.ts (TS-11)
17. Refatorar init do Whisper para funcao compartilhada (PY-09)

MomAIOS v1.4.0 e um projeto ambicioso com arquitetura solida, mas que acumulou divida tecnica e problemas de seguranca ao longo do desenvolvimento. Os problemas criticos de seguranca sao resolviveis em dias; os problemas estruturais (funcao monolitica, estado compartilhado) exigem refatoracao mais planejada mas trarao ganhos proporcionais de manutibilidade.

Relatorio gerado em 22 de maio de 2026 por auditoria automatizada de codigo estatico.